Brukerautentisering

Agenda

Måter å autentisere på

Rammeverk

Eksamensoppgaver fortøpende

Kontekst: Tilgangskontroll

Prosessen om å bestemme **hvem som får tilgang til hva**

<u>Flere trinn:</u>

1. Identifisering “Hvem sier du at du er?”
2. (bruker)Autentisering: “Bevis det!” << Her er vi
3. Autorisasjon: “Hva har du lov til?”

Begreper

Brukerautentisering

- Å bevise eierskap til en identitet

Man bruker en autentikator til brukerautentisering.

Deles inn i:

- Noe du vet
- Noe du har
- Noe du er

Noe du vet - Passord

Det mest utbredte av autentikatorer.

Mange problemer med passord:

- huske de
- lage nye hver gang
- passe på at de er vanskelige å gjette og brute force

Noe du vet - cont.

Råd for passord:

- Langt nok passord (minst 13)
- Flere kategorier av tegn (@, #, etc.)
- Ikke gjenbruk passord
- Oppbevar passord sikkert (yubi keys, proton pass, bitwarden etc)
- Endre passord dersom kompromittert (haveibneepwned)
    - Oppdater jevnlig

Lagring av passord

Unix: /etc/shadow

Windows: \windows\system32\config\sam

Mac: /var/db/dslocal/nodes/Default/users/<username>.plist

Databaser:

- Klartekst < hashet < hashet og saltet
- Ikke uvanlig at passorddatabaser stjeles / lekkes

Salting: legger til data (salt) til brukerens passord før det hashes.

Eksempel på Cyberchef

Passordlengder

Anta engelsk alfabet lowercase (26 tegn):

- *Minst 13 bokstaver.*
- Hvor mange ulike kombinasjoner har vi da?

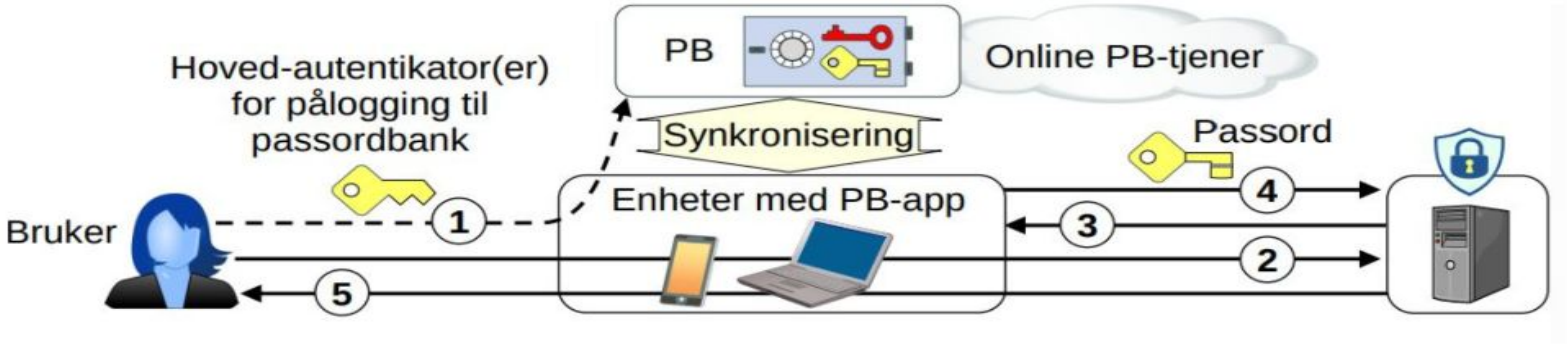
Passordbanker

eller password manager:

- Samler, skaper og holder på passord så alt er på et sted

Kan være:

- Innebygd i OS
- Innebygd i nettleser
- Tredjeparts passordbanker



Eksamen 2022

8.1 **8.1 Passordsikkerhet**

Velg riktig sikkerhetstiltak i en kolonne til høyre for å dekke hvert sikkerhetskrav i venstre kolonne.
Poeng: 0,5 for hver riktig, -0.5 for for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

Angi riktig sikkerhetstiltak for hvert krav

	Komplekse passord	Salting	Hashing	Tilgangskontroll
Det skal ikke være mulig å benytte forhåndsgenererte hash-tabeller for å cracke passord i databasen.	○	○	○	○
Kun autoriserte skal kunne lese passorddatabasen.	○	○	○	○
Det skal være svært vanskelig å cracke et saltet passord fra databasen.	○	○	○	○
Passord skal ikke ligge i klartekst i passorddatabasen.	○	○	○	○

Maks poeng: 2

Eksamen 2022

8.1 **8.1 Passordsikkerhet**

Velg riktig sikkerhetstiltak i en kolonne til høyre for å dekke hvert sikkerhetskrav i venstre kolonne.
Poeng: 0,5 for hver riktig, -0.5 for for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.

Angi riktig sikkerhetstiltak for hvert krav

	Tilgangskontroll	Salting	Komplekse passord	Hashing
Kun autoriserte skal kunne lese passorddatabasen.	✔			
Det skal være svært vanskelig å cracke et saltet passord fra databasen.			✔	
Passord skal ikke ligge i klartekst i passorddatabasen.				✔
Det skal ikke være mulig å benytte forhåndsgenererte hash-tabeller for å cracke passord i databasen.		✔		

Maks poeng: 2

Eksamen 2024

11 Passordkompleksitet

Passordpolicyen har blitt endret fra en passordlengde 10 tegn til 14 tegn. Vi antar at systemet støtter standard (engelsk) 105 forskjellige tegn (store og små bokstaver, tall og spesialtegn). Hvor mye mer komplekst blir passordet?

Poeng: 1 for riktig; 0 for feil eller ubesvart; maks 1, minimum 0.

Velg ett alternativ:

- 105 ganger
- Umulig å si
- 105^4
- 105*4

Maks poeng: 1

Eksamen 2024

11 Passordkompleksitet

Passordpolicyen har blitt endret fra en passordlengde 10 tegn til 14 tegn. Vi antar at systemet støtter standard (engelsk) 105 forskjellige tegn (store og små bokstaver, tall og spesialtegn). Hvor mye mer komplekst blir passordet?

Poeng: 1 for riktig; 0 for feil eller ubesvart; maks 1, minimum 0.

Velg ett alternativ:

- 105^4 ✔
- 105*4
- 105 ganger
- Umulig å si

Maks poeng: 1

Noe du har

OTP-brikker (one time password):

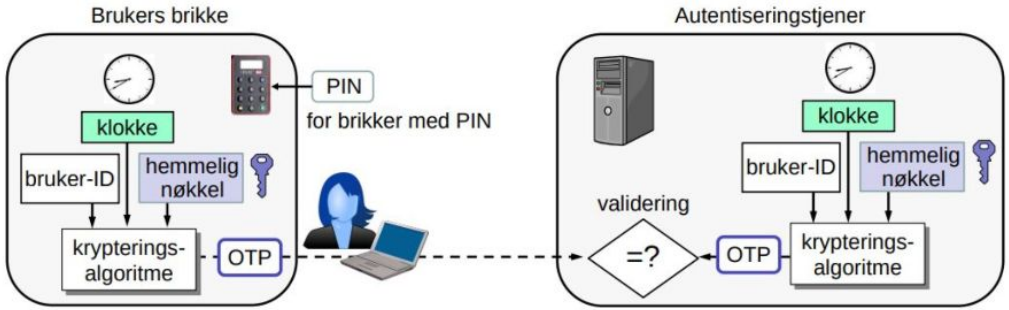
- Eksempel Bank ID
- Inneholder en klokke som bestemmer gyldighet

Adgangskort og ID-kort

- Eksempel: uio-kort
- Kortene har en chip og en antenne

Sekundære kanaler: Apper, sms, mail

- Brukes ofte til Fler-/to faktor

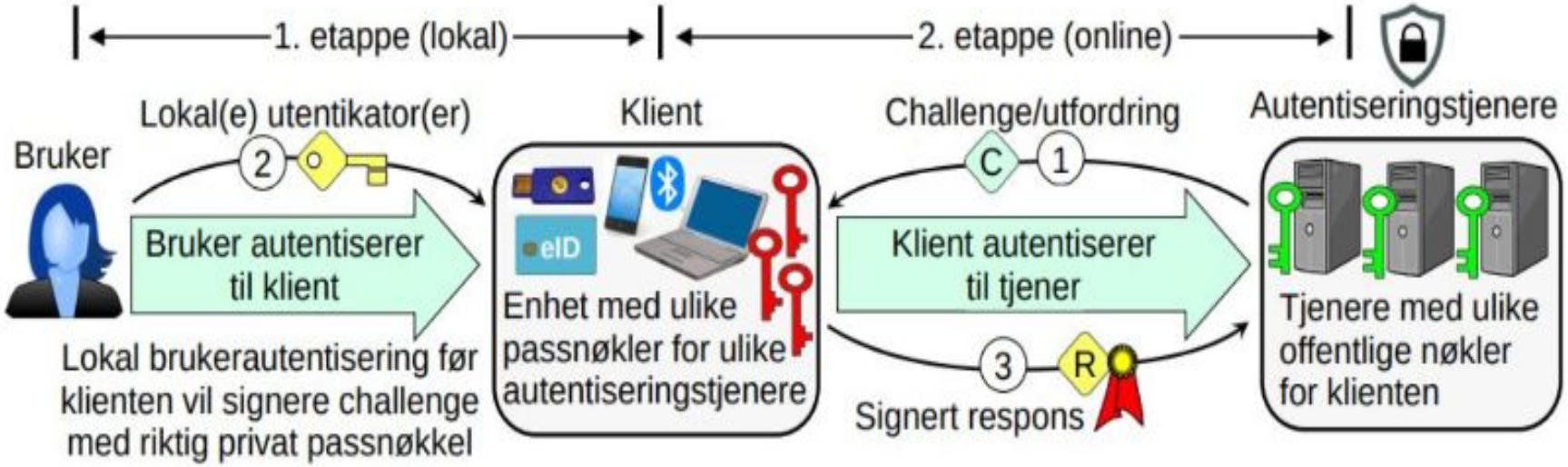


Passkeys / passnøkler

Passnøkler, FIDO og WebAuthn (Oauth)

- Klient/enhet autentiserer brukeren med en unik domenebundet nøkkel
- Lokal brukerautentisering (PIN/biometri) kreves før signering
- Passnøkler lagres i skybank, ekstern enhet/brikke
- Erstatter passord, støttes av FIDO2 og WebAuthn (standarder)
- Phishing resistente, siden de er bundet til domene.
    - Fake nettside = ingen nøkkel

Passkeys / passnøkler



Eksamen 2023

33 Passnøkler

Phishingresistent autentisering med passnøkler (også kalt FIDO eller WebAuthn) er et aktuelt tema. Indiker om hvert av utsagnene nedenfor er sant eller usant.

Poeng: 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 3; minimum 0.

Si om hvert utsagn er sant eller usant.

	Sant	Usant
En passnøkkel inneholder autentiseringstjenerens URL.	○	○
Selv om phishingresistent autentisering gjør at brukeren advares om falske nettsider, kan brukeren i nettleseren velge å ignorere advarselen.	○	○
Hver bruker har kun én passnøkkel som benyttes for ulike nettsteder.	○	○
En passnøkkel er en privat (asymmetrisk) kryptografisk nøkkel.	○	○
Brukere som mister enheter der passnøkler er lagret må generere nye passnøkler.	○	○
Brukerautentisering med passnøkler foregår i to etapper, en lokal, og en online.	○	○

Maks poeng: 3

Eksamen 2023

33 Passnøkler

Phishingresistent autentisering med passnøkler (også kalt FIDO eller WebAuthn) er et aktuelt tema. Indiker om hvert av utsagnene nedenfor er sant eller usant.

Poeng; 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 3; minimum 0.

Si om hvert utsagn er sant eller usant.

	Sant	Usant
En passnøkkel inneholder autentiseringstjenerens URL.	✔	
Selv om phishingresistent autentisering gjør at brukeren advares om falske nettsider, kan brukeren i nettleseren velge å ignorere advarselen.		✔
Hver bruker har kun én passnøkkel som benyttes for ulike nettsteder.		✔
En passnøkkel er en privat (asymmetrisk) kryptografisk nøkkel.	✔	
Brukere som mister enheter der passnøkler er lagret må generere nye passnøkler.		✔
Brukerautentisering med passnøkler foregår i to etapper, en lokal, og en online.	✔	

Maks poeng: 3

Eksamen 2022

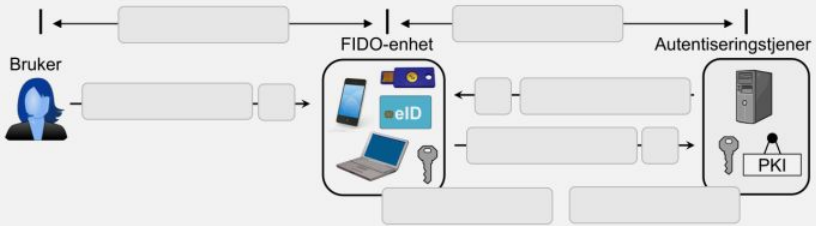
8.3 8.3 FIDO-autentisering

Figuren nedenfor viser scenario for brukerautentisering med FIDO 2.0-protokollen. Sett inn elementene i riktig felt, samt tallene 1,2,3 (i de små feltene) for å indikere rekkefølgen på meldingene.
Poeng: 0,5 for riktig, -0.5 for feil, 0 for ubesvart, 5 for alle riktig, minimum 0.

Hjelp

Privat FIDO-nøkkel	1
Autentikator(er)	Utfordring
Autentiseringsetappe 1	3
Respons	Autentiseringsetappe 2
2	Offentlig FIDO-nøkkel

Brukerautentisering med FIDO 2.0



Maks poeng: 5

Eksamen 2022

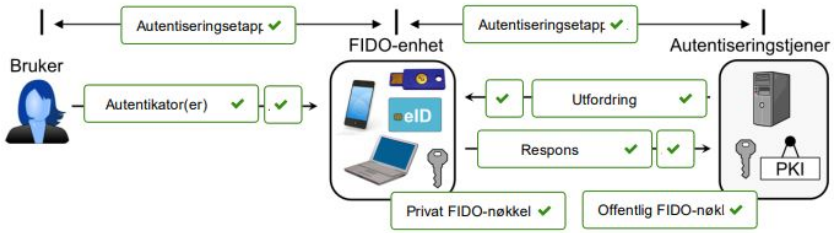
8.3 **8.3 FIDO-autentisering**

Figuren nedenfor viser scenario for brukerautentisering med FIDO 2.0-protokollen. Sett inn elementene i riktig felt, samt tallene 1,2,3 (i de små feltene) for å indikere rekkefølgen på meldingene.
Poeng: 0,5 for riktig, -0.5 for feil, 0 for ubesvart, 5 for alle riktig, minimum 0.

Hjelp

Utfordring	Respons
Autentiseringsetappe 1	3
Offentlig FIDO-nøkkel	2
Autentiseringsetappe 2	1
Privat FIDO-nøkkel	Autentikator(er)

Brukerautentisering med FIDO 2.0



Maks poeng: 5

Noe du er

Gjennkjenner noen basert på fysiologiske egenskaper

F.eks:

- Fingeravtrykk
- Ansiktsgjenkjenning
- Iris
- Stemme
- Osv.

Krav til biometri

Universalitet: *alle har egenskapen*

Særpreg: *egenskapen er unik for hver person*

Permanens: egenskapen *endrer seg lite over tid*

Målbarhet: *egenskapen er lett å registrere med en sensor*

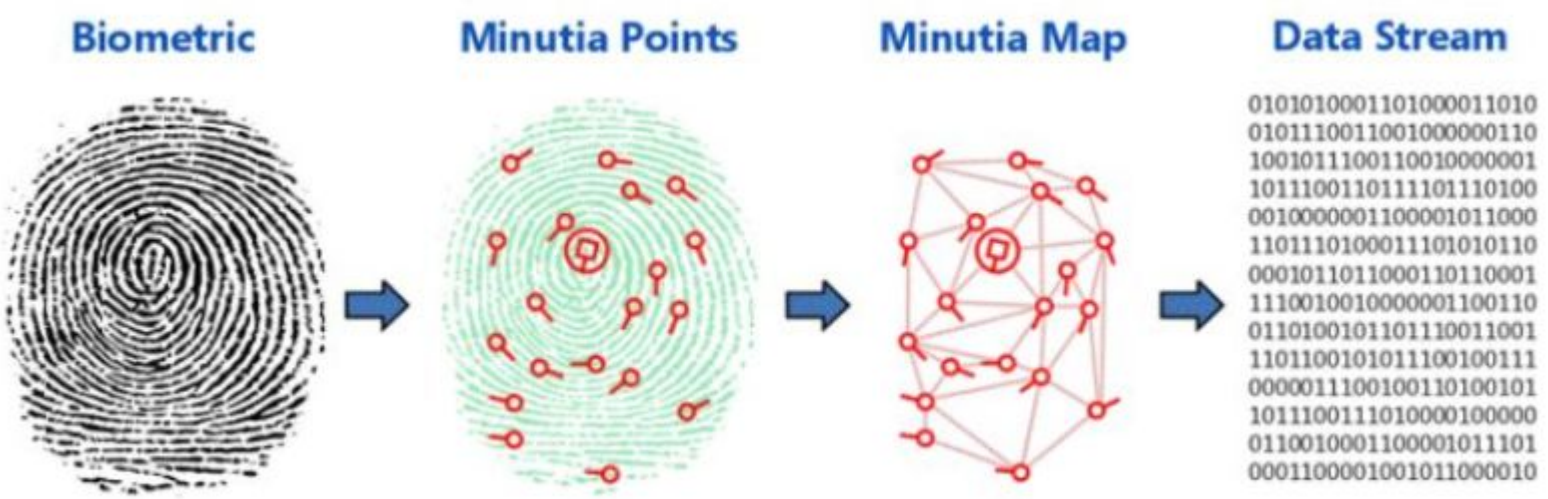
Nøyaktighet: *systemer gjør få feil*

Ytelse: *raskt og ressurseffektiv*

Aksept: *villig til å brukes*

Beskyttelse mot forfalskning: *vanskelig å lure*

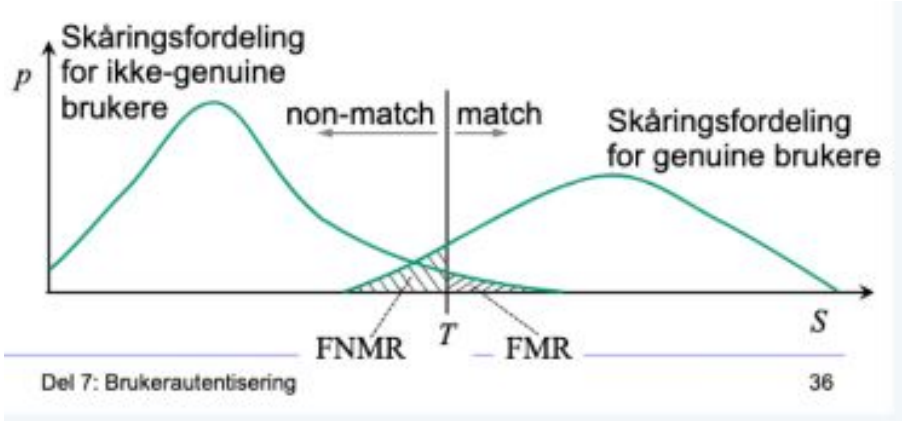
Eksempel: Fingeravtrykk



Noe du er - nøyaktighet

Har krav om nøyaktighet.

- FMR: False Match Rate:
  - *False Positive*: hvor ofte en feil person blir godtatt
- FNMR: False Non Match Rate
  - *False Negative*: Hvor ofte riktig person blir avvist
- EER: Equal Error Rate
  - Lik feil rate, altså FMR = FNMR



Nøyaktighet cont.

FMR = falske positive / alle forsøk fra inntrengere

FNMR = falske negative / alle forsøk fra ekte bruker

Eksempel:

- 100 forsøk fra inntregere, og 2 slipper inn: FMR = 2 %
- Du prøver 100 ganger (legitimt), og blir avvist 5 ganger: FNMR = 5 %

Nøyaktighet cont.

Andre begreper:

- True Match Rate (TMR)
- True Non-Match Rate (TNMR)

Litt mer intuitivt.

Altså, de vurderer **sanne** positiver og negativer.

Oppsummert:

FMR = falske positive / alle forsøk fra inntrengere

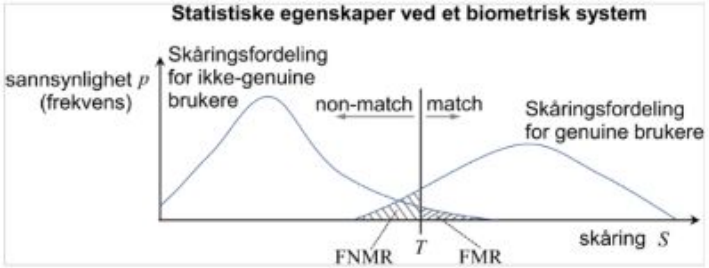
FNMR = falske negative / alle forsøk fra ekte bruker

TMR = Sanne positive / alle forsøk fra ekte bruker

TNMR = Sanne negative / alle forsøk fra inntrengere

Eksamen 2022

8.2 **8.2 Biometris system**



Statistiske egenskaper ved et biometrisk system reflekterer systemets kvalitet, som illustrert i figuren over.
Et biometrisk system blir testet med 100 genuine brukere som forsøker å logge inn på egen konto, og 100 ikke-genuine brukere som forsøker å logge inn på en annen konto enn sin egen.
Anta at 96 genuine brukere og 6 ikke-genuine brukere blir godtatt.
Oppgi følgende rater som et desimaltall (bruk punktum som skille mellom heltall og desimaltall).
Merk at ratene ikke har noen sammenheng med størrelsen på feltene i figuren over.

TMR (True Match Rate):

TNMR (True Non-Match Rate):

FMR (False Match Rate):

FNMR (Nalse Non-Match Rate):

Poeng: 0.5 for riktig, 0 for feil eller ubesvart, 2 for alle riktig, minimum 0.

Maks poeng: 2

TL;DR

- 100 forsøk fra ekte brukere, 96 blir godtatt
- 100 forsøk fra inntrengere, 6 blir godtatt

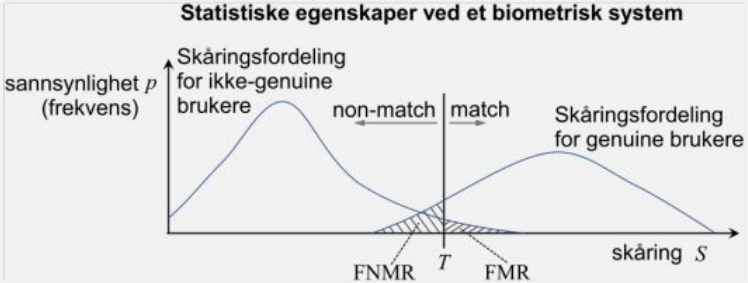
Ekte brukere (100 forsøk):

- TMR?
- FNMR?

Inntrengere (100 forsøk):

- FMR?
- FNMR?

8.2 8.2 Biometris system



Statistiske egenskaper ved et biometrisk system reflekterer systemets kvalitet, som illustrert i figuren over.
Et biometrisk system blir testet med 100 genuine brukere som forsøker å logge inn på egen konto, og 100 ikke-genuine brukere som forsøker å logge inn på en annen konto enn sin egen.
Anta at 96 genuine brukere og 6 ikke-genuine brukere blir godtatt.
Oppgi følgende rater som et desimaltall (bruk punktum som skille melliom heltall og desimaltall).
Merk at ratene ikke har noen sammenheng med størrelsen på feltene i figuren over.

TMR (True Match Rate): (0.96)

TNMR (True Non-Match Rate): (0.94)

FMR (False Match Rate): (0.06)

FNMR (Nalse Non-Match Rate): (0.04)

Poeng: 0.5 for riktig, 0 for feil eller ubesvart, 2 for alle riktig, minimum 0.

Maks poeng: 2

Eksamen 2021

24 **6.2 Biometrisk system**

Poeng for hvert svar: 0,5 for riktig, -0,5 for feil, maks 3, minimum 0.

Når terskelverdien for match (for å bli godtatt) heves, vil FMR Velg alternativ (forbli uendret, øke, minske).

Et ideelt biometrisk system er når Velg alternativ (FMR = FNMR, FNMR = 0, FMR = 0, FMR = FNMR = EER = 0)-

PAD (Presentation Attack Detection) er å

Velg alternativ (oppdage når en ikke-genuin bruker blir feilaktig godtatt, oppdage når en genuin bruker blir feilaktig avvist, oppdage forsøk på forfalskning av biometri).

Å oppdage forfalskning av biometri er Velg alternativ (enkelt med, vanskelig på tross av) lav EER (Equal Error Rate).

Anta at et biometrisk system har blitt testet med 100 genuine brukere, og 100 ikke-genuine brukere. Testingen viste at systemet hadde FMR = 0,05, og FNMR = 0,07.

Hvor mange ikke-genuine brukere ble godatt? Svar med heltall: .

Hvor mange genuine brukere ble avvist? Svar med heltall: .

Maks poeng: 3

24 ## 6.2 Biometrisk system

Poeng for hvert svar: 0,5 for riktig, -0,5 for feil, maks 3, minimum 0.

Når terskelverdien for match (for å bli godtatt) heves, vil FMR Velg alternativ (forbli uendret, øke, minske).

Et ideelt biometrisk system er når Velg alternativ (FMR = FNMR = EER = 0, FMR = FNMR, FMR = 0, FNMR = 0)-

PAD (Presentation Attack Detection) er å

Velg alternativ (oppdage forsøk på forfalskning av biometri, oppdage når en genuin bruker blir feilaktig avvist, oppdage når en ikke-genuin bruker blir feilaktig godtatt).

Å oppdage forfalskning av biometri er Velg alternativ (enkelt med, vanskelig på tross av) lav EER (Equal Error Rate).

Anta at et biometrisk system har blitt testet med 100 genuine brukere, og 100 ikke-genuine brukere. Testingen viste at systemet hadde FMR = 0,05, og FNMR = 0,07.

Hvor mange ikke-genuine brukere ble godatt? Svar med heltall: (5).

Hvor mange genuine brukere ble avvist? Svar med heltall: (7).

Maks poeng: 3

Flerfaktor

Brukes som regel ikke flere enn to typer autentisering (to faktor)

Uio bruker (som dere vet) to-faktor:

- Noe du vet (brukernavn og passord)
- Noe du har (Authenticator app)

Rammeverk

Noen rammer for hva som er *god nok brukerautentisering*

- LAVT: 1-faktor, eks. kun passord
- BETYDELIG:
  - 2-faktor
    - passord
    - sms/epost
- HØYT:
  - 2-faktor
    - passord
    - bankID brikke/app (sann auth)

Veileder/standard for autentisering	***Garantinivå for autentisering***			
SP 800-63-4 Digital Identity Guidelines NIST, USA 2025		Assurance Level 1	Assurance Level 2	Assurance Level 3
Assurance levels for electronic identification means eIDAS 2.0, EU 2024		Low	Substantial	High
Veileder for identifikasjon og sporbarhet DigDir 2022 (basert på eIDAS 1.0, 2018)		LAVT	BETYDELIG	HØYT
IS 29115 Entity authentication assurance framework ISO/IEC 2013	Low (1)	Medium (2)	High (3)	Very High (4)

Kategorier av krav

a) ID-registrering og autentikatorhåndtering

Metoder for sjekk av identitet og klargjøring av autentikatorer

Krav til identitetsbevis og korrekt registrering:
- fødselsattest, pass, biometri

Krav til klargjøring og håndtering av autentikator:
- overlevering og gjenoppretting, fysisk, post eller online

b) Autentiseringsmetode

Teknologi og kombinasjon av metoder for brukerautentisering.

Krav til autentiseringsmetoder:
- passordlengde og kvalitet
- kryptografisk styrke og PKI
- flere autentiseringsfaktorer (2FA, MFA)
- phishingresistens (kun nevnt i USA NIST SP 800-63-4)

c) Fødereringssikkerhet

Tillitsnivåer og sikkerhet i samhandling mellom IdP og SP.

Krav til sertifisering av IdP (autentiseringstjener) og ID-portaler, og juridiske avtaler mellom interessenter.

BankID: krav

BankID som eksempel på alle tre krav

- a) Banken sjekker passet ditt før du får BankID.

- b) Du logger inn med personlig kode pluss app (2FA).

- c) BankID (IdP) bekrefter identiteten din overfor for eksempel NAV eller Skatteetaten (SP), og de stoler på BankID fordi det finnes avtaler og sertifisering.

EUs rammeverk eIDAS

Norge sin standard er basert på denne.

Low Assurance eDAS LoA-1	Substantial Assurance eIDAS LoA-2	High Assurance eIDAS LoA-3
Limited degree of confidence in the claimed or asserted identity of a person	Substantial degree of confidence in the claimed or asserted identity of a person	High degree of confidence in the claimed or asserted identity of a person



EU sitt symbol for kvalifiserte tillitstjenester

Eksamen 2022

8.4 **8.4 Rammerk for e-Autentisering**

Rammeverk for e-Autentisering og uavviselighet definerer autentiseringsnivåer for bruk i e-Forvaltning (online tjenester til innbyggere) i Norge. Ulike autentiseringsløsninger gir ulike autentiseringsnivåer.

Gi et eksempel på en løsning som gir nivå HØY: Velg alternativ (Biometri, BankID, FIDO, MinID).

Gi et eksempel på en løsning som bare gir nivå MODERAT: Velg alternativ (FIDO, Biometri, MinID, BankID)

Poeng: 0,5 for hver riktig, -0.5 for feil, 0 for ubesvart, 1 for begge riktig, minimum 0.

Maks poeng: 1

Eksamen 2022

8.4 **8.4 Rammerk for e-Autentisering**

Rammeverk for e-Autentisering og uavviselighet definerer autentiseringsnivåer for bruk i e-Forvaltning (online tjenester til innbyggere) i Norge. Ulike autentiseringsløsninger gir ulike autentiseringsnivåer.

Gi et eksempel på en løsning som gir nivå HØY: Velg alternativ (MinID, BankID, FIDO, Biometri).

Gi et eksempel på en løsning som bare gir nivå MODERAT: Velg alternativ (MinID, BankID, Biometri, FIDO)

Poeng: 0,5 for hver riktig, -0.5 for feil, 0 for ubesvart, 1 for begge riktig, minimum 0.

Maks poeng: 1

Eksamen 2021

26 **6.4 Rammeverk for e-autentisering**

Tre rammeverk for e-autentisering er
- NIST SP800-63-3, USA 2017
- eIDAS, EU 2014
- RAU (Rammeverk for autentiserinig og uavviselighet), Norge 2008

For hver karakteristikk, angi tilhørende rammeverk for e-autentisering. Poeng: 0,5 for hver korrekt, -0.5 for for hver feil, 0 for intet valg, maks 2, minimum 0.

Angi tilhørende rammeverk for e-autentisering

	NIST, USA 2017	eIDAS, EU 2014	RAU, Norge 2008
Definerer 4 autentiseringsnivåer	○	○	○
Beskriver ikke krav til registrering av ID	○	○	○
Beskriver krav til ID-føderering	○	○	○
Beskriver 3 kategorier krav til autentiseringsløsninger	○	○	○

Maks poeng: 2

Eksamen 2021

26 **6.4 Rammeverk for e-autentisering**

Tre rammeverk for e-autentisering er
- NIST SP800-63-3, USA 2017
- eIDAS, EU 2014
- RAU (Rammeverk for autentiserinig og uavviselighet), Norge 2008

For hver karakteristikk, angi tilhørende rammeverk for e-autentisering. Poeng: 0,5 for hver korrekt, -0.5 for for hver feil, 0 for intet valg, maks 2, minimum 0.

Angi tilhørende rammeverk for e-autentisering

	NIST, USA 2017	RAU, Norge 2008	eIDAS, EU 2014
Beskriver krav til ID-føderering	✔		
Beskriver 3 kategorier krav til autentiseringsløsninger			✔
Beskriver ikke krav til registrering av ID		✔	
Definerer 4 autentiseringsnivåer		✔	

Maks poeng: 2